

Category 4: Cybersecurity, Governance & Compliance Manual

This comprehensive manual outlines the organizational standards for SecOps, internal auditing, and regulatory compliance (SOC2, GDPR).

SEC-GOV-001: Data Classification Policy

Data must be classified to determine appropriate security controls.

Level	Definition	Handling
Public	Approved for public release	No restrictions
Internal	Company-wide use	Access control required
Confidential	Sensitive business data	Encryption required
Restricted	Highly sensitive (e.g., PII)	Strict access, mandatory encryption

SEC-GOV-002: Identity and Access Management (IAM)

Access is granted based on the **Principle of Least Privilege (PoLP)**. Users are assigned roles, not individual permissions.

SEC-GOV-003: Encryption Standards

Data at-rest must be encrypted using **AES-256**. Data in-transit must be encrypted using **TLS 1.3** exclusively.

SEC-GOV-004: Incident Response Plan

In the event of a breach: 1) Identify 2) Contain 3) Eradicate 4) Recover 5) Lessons Learned.

SEC-GOV-005: Vulnerability Disclosure Program (VDP)

Security researchers may report vulnerabilities via our VDP portal. Findings are rewarded based on severity score.

SEC-GOV-006: SOC 2 Type II Compliance

Continuous evidence collection for Security, Availability, Processing Integrity, Confidentiality, and Privacy.

SEC-GOV-007: GDPR and CCPA Compliance

Automated workflow for "Right to be Forgotten" requests must be processed within 30 days.

SEC-GOV-008: Third-Party Vendor Risk Assessment

All vendors must complete a security questionnaire and undergo an annual audit.

SEC-GOV-009: Penetration Testing Schedule

Internal penetration tests occur quarterly. Third-party testing occurs annually.

SEC-GOV-010: Endpoint Security Policy

All corporate devices must be managed via MDM (Mobile Device Management) with full-disk encryption and mandatory MFA.

SEC-GOV-011: Key Management Service (KMS)

Master keys must be rotated every 90 days. Key material is backed by Hardware Security Modules (HSM).

SEC-GOV-012: Insider Threat Monitoring

All production system logs are audited in real-time to detect anomalous user behavior.

SEC-GOV-013: Physical Security Guidelines

Offices require badge access. Biometrics for co-location centers.

SEC-GOV-014: Business Continuity and Disaster Recovery (BCDR)

Recovery Point Objective (RPO) is 1 hour; Recovery Time Objective (RTO) is 4 hours.

SEC-GOV-015: Security Awareness Training

Mandatory training upon hire and quarterly phishing simulations.